



Security Audit

Monstro USDC

Table of Contents

Executive Summary	4
Project Context	4
Audit Scope	7
Security Rating	9
Code Quality	10
Audit Resources	10
Dependencies	10
Severity Definitions	11
Status Definitions	12
Audit Findings	12
Conclusion	19
Our Methodology	20
Disclaimers	22
About Hashlock	23

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The Monstro USDC team partnered with Hashlock to conduct a security audit of their smart contracts. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

Monstro USDC, is an ERC-4626 vault on Base that wraps USDC into yield-bearing mUSDC shares. The vault is designed to make idle USDC liquidity productive across Monstro USDC products while keeping accounting transparent, non-custodial, and fully on-chain.

Users deposit USDC and receive mUSDC shares representing their proportional ownership of the vault. As protocol fees and revenue are retained in the vault, the mUSDC exchange rate is designed to appreciate over time. The vault uses fixed, immutable fee logic and does not depend on discretionary admin yield controls.

mUSDC will first be integrated with Based Loans, Monstro's fixed-term, zero-liquidation lending protocol, so lender liquidity can continue earning while waiting to be matched into loans.

Project Name: Monstro USDC

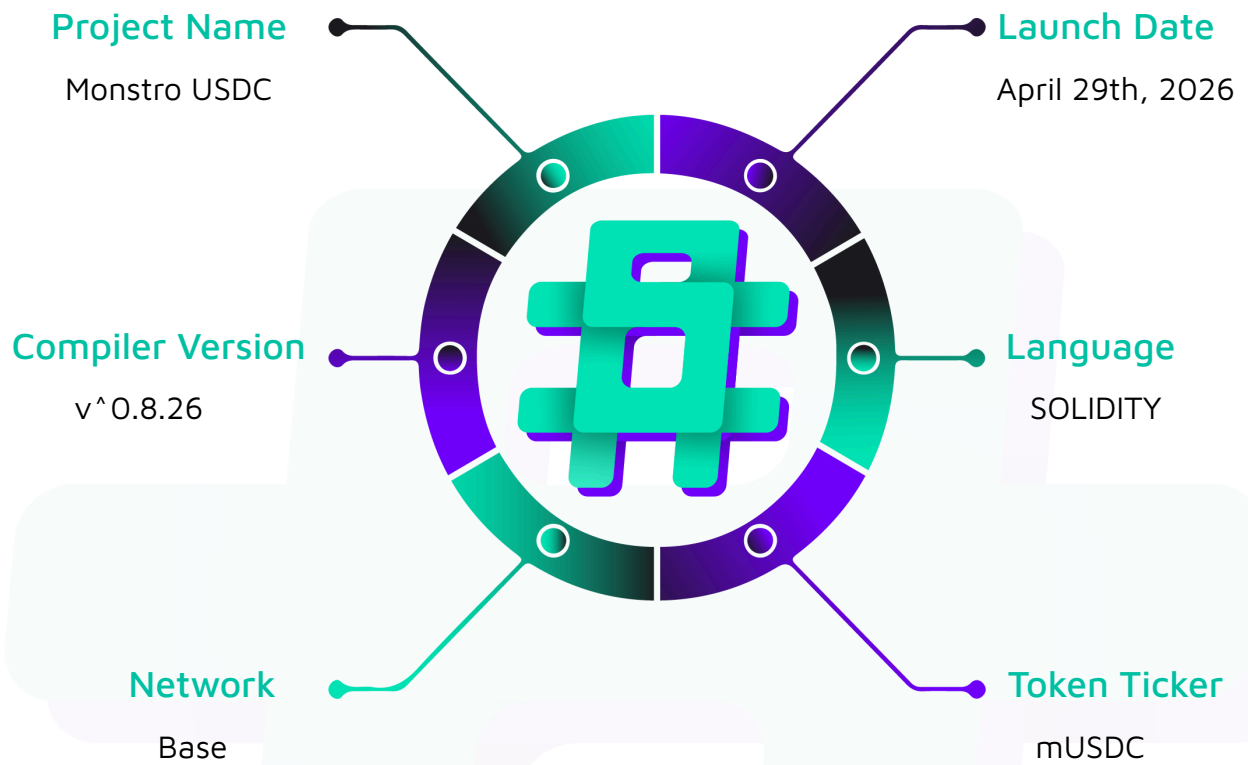
Project Type: Defi

Compiler Version: ^0.8.26

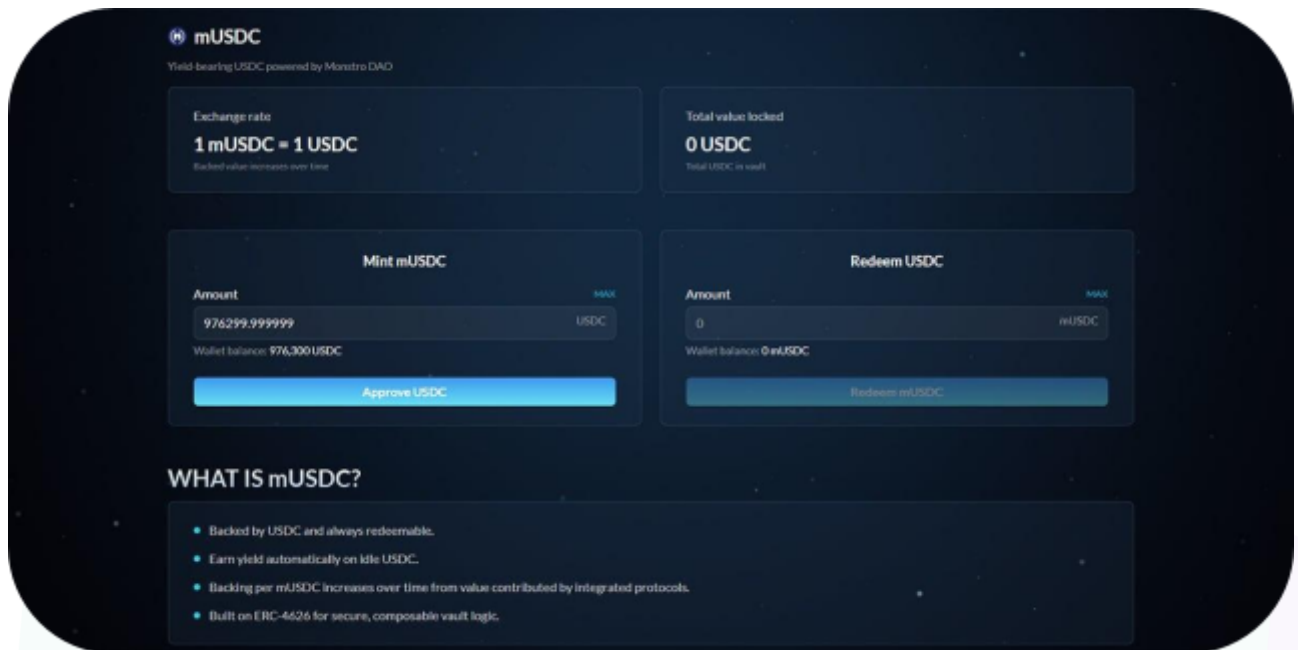
Website: <https://monstrodefi.com>

Logo:



Visualised Context:

Project Visuals:



Audit Scope

We at Hashlock audited the solidity code within the Monstro USDC project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	Monstro USDC Smart Contracts
Network	Ethereum
Language	Solidity
Audit Date	April, 2026
Contract 1	vaults/MonstroUSDC.sol
Audited GitHub Commit Hash	6f2aee66b221499cd2bc16e541647677ef8e0954
Fix Review GitHub Commit Hash	e4a22769ffd145c9fd01811e04551e7f3604873b

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces, and the protocol uses a list of Open Zeppelin contracts.



The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Audit Findings](#) section. The list of audited assets is presented in the [Audit Scope](#) section and the project's contract functionality is presented in the [Intended Smart Contract Functions](#) section.

All vulnerabilities initially identified have now been resolved.

Hashlock found:

1 Medium severity vulnerabilities

3 Low severity vulnerabilities

Caution: Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.

Code Quality

This audit scope involves the smart contracts of the Monstro USDC project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring were recommended to optimize security measures.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the Monstro USDC project smart contract code in the form of GitHub access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.

Apart from libraries, its functions are used in external smart contract calls.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-severity issues should be resolved before deployment. While they do not typically lead to a complete loss of funds, they may result in partial loss of funds or unintended behavior under certain conditions.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies.
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue.
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Medium

[M-01] MonstroUSDC#deposit/MonstroUSDC#mint - Users claim a portion of their deposit fee after deposit

Description

The current order of execution of deposit actions create a state where depositors claim back part of their deposit fee

Vulnerability Details

When a user deposits or mints, the functions

compute gross and netAmounts using current totalSupply and totalAssets values

transfers net + fee in

This order of execution means that when the resulting share amount (deposit) or resulting deposit amount (mint) is computed, the fee has not yet been distributed to current share holders

when fee is then transferred in, it is split equally amongst all shares including the shares minted as a result of the current call

eg

```
totalSupply = 1000e6
```

```
totalAssets = 1000e6
```

```
deposit call with assets = 1000e6
```

CURRENT FLOW:

```
fee is computed at 5e5
```

```
shares = (1000e6 - 5e5) * 1
```

```
finalSupply = 1999.5e6
```



```
finalAssets = 2000e6
```

```
finalDepositAssets = 999.5e6 * 2000e6 / 1999.5e6 =~999.75 instead of 999.5
```

Impact

Deposit fee is not properly deposited to previous depositors.

Recommendation

MonstroUSDC#deposit should

compute the fee

transfer the fee in first

do conversion to shares afterwards

MonstroUSDC#mint could compute gross using the formula

```
solidity
```

```
gross = shares * (totalAssets() + 1) * BPS_DENOMINATOR / ((totalSupply() + 1) *  
(BPS_DENOMINATOR - MINT_FEE_BPS) - shares * MINT_FEE_BPS)
```

It is also important to note that would need to be followed by updating the vaults view functions ie previewDeposit and previewMint

Status

Resolved

Low

[L-01] MonstroUSDC#_withdrawWithFee - emits wrong Withdraw event

Description

By specification

<https://eips.ethereum.org/EIPS/eip-4626#:~:text=sender%20has%20exchanged%20shares%2C%20owned%20by%20owner%2C%20for%20assets%2C%20and%20transferred%20those%20assets%20to%20receiver.>

The assets param emitted by the ERC4626 Withdraw event should be the amount received ie amount transferred to the receiver however the internal withdraw function _withdrawWithFee emits the gross amount which is equal to (amount transferred + fee) breaking specification

Impact

Off chain systems that rely on the Withdraw event and expects the contract to follow the eip may be misled

Recommendation

Emit the net amount instead of the gross amount.

Status

Resolved

[L-02] MonstroUSDC#maxMint - returns wrong value

Description

By specification

<https://eips.ethereum.org/EIPS/eip-4626#::~text=MUST%20return%20the%20maximum%20amount%20of%20shares%20mint%20would%20allow%20to%20be%20deposited%20to%20receiver%20and%20not%20cause%20a%20revert.>

currently maxMint returns `type(uint).max`

however a `type(uint).max` deposit is never possible at any point due to the `mintFee`, if said value is ever passed, the resulting gross would be more than `type(uint).max` causing an overflow revert

Impact

Breakage of eip specification.

Recommendation

Override `maxMint` to account for `mintFee`

Status

Resolved

[L-03] MonstroUSDC#deposit/MonstroUSDC#mint/MonstroUSDC#withdraw/MonstroUSDC#redeem - Initial mintFee and last redeemFee are lost to deadShares

Description

Fee is paid on deposits and redeem to all shares that are in the vault including dead shares minted to prevent inflation attack

if the first deposit is a large one, a reasonable fee amount may be paid completely to the dead shares, the same thing happens in the scenerio where all users exit the vault ie the last redemption fee is paid completely to the dead shares

Impact

Large amounts of usdc may be lost to dead address.

Recommendation

Add a check on mint action to only charge fee if the previous supply > SEED_AMOUNT and redeem actions should only charge fee if totalSupply after redeem > SEED_AMOUNT

Status

Resolved

Centralisation

The Monstro USDC project values decentralisation alongside security and utility.

The protocol's functions are designed to operate independently, minimising reliance on the internal team and hardcoded values, while maintaining robust security and functionality.



Centralised

Decentralised

Conclusion

After Hashlock's analysis, the Monstro USDC project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved . Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.